Нормативно-правовая база в области информационной безопасности

Список CVE-2025-X в браузере Google Chrome, связанных с ошибкой в JavaScript-движке V8

- CVE-2025-13223 (CVSS 8.8)
- CVE-2025-6554 (CVSS 8.1)
- CVE-2025-9132 (CVSS 8.8)

Примеры из практики

- Компания: Телекоммуникационный оператор "МТС"
- Нарушение: Неудовлетворительный уровень защиты персональных данных абонентов (2023 год)
- Применённый закон: ФЗ-152 «О персональных данных» (ст. 19, 24)
- Наказание: Штраф 3,5 млн рублей за хранение данных без должного шифрования и контроля доступа

Примеры из практики

- Компания: Крупный банк Москвы
- Нарушение: Утечка данных клиентов через незашифрованный API-интерфейс (2024 год)
- Применённый закон: ФЗ-152, ст. 60 (защита ПДн) + ФЗ-187 (КИИ)
- Наказание: Штраф 1,2 млн руб. + проведение внеочередного аудита в течение 30 дней

Примеры из практики

- Компания: Региональная энергокомпания "ОблЭлектро"
- Нарушение: Не проводилась аттестация КИИ более 4 лет, отсутствие уведомлений об инцидентах
- Применённый закон: ФЗ-187 «О безопасности КИИ» + Приказ ФСТЭК №15
- Наказание: Штраф 2,0 млн рублей + отзыв лицензии на временный срок (6 месяцев)

Примеры из практики

- Субъект: Служба безопасности государственного учреждения
- Нарушение: Несанкционированный доступ к информационной системе (ст. 272 УК РФ)
- Применённый закон: ФЗ-149, ст. 15 + Уголовный кодекс РФ (ст. 272, 273)
- Наказание: Лишение свободы администратора системы на 1 год 6 месяцев + компенсация ущерба в размере 2,5 млн рублей

Примеры из практики

- Компания: Производство, использующее зарубежный софт для обработки данных
- Нарушение: Использование незашифрованных каналов связи и криптографических средств не сертифицированных в РФ
- Применённый закон: Приказ ФСБ №47 о КЭП + ФЗ-152
- Наказание: Штраф 300 тыс. рублей + замена средства на отечественные аналоги

Федеральное законодательство РФ

ФЗ-149 от 27.07.2006 г. «Об информации, информационных технологиях и о защите информации»

Дата принятия: 27 июля 2006 года

Основной смысл: Фундаментальный закон, определяющий правовые основы оборота и защиты информации

Ключевые статьи для ИБ: Статья 13 — защита информации; Статья 15 — ответственность за доступ к защищаемой информации

Задачи:

1. Определение статуса информации в РФ
2. Регулирование доступа к защищённым ресурсам
3. Требования к классификации информации
4. Контроль за распространением защищаемой информации
5. Защита от несанкционированного доступа

Обязательные требования для компаний:

1. Система классификации данных — все информационные ресурсы должны быть классифицированы (секретно/внутренне/общедоступно)
2. Допуск к информации — только авторизованный доступ по принципу наименьших привилегий
3. Локализация серверов — хранение данных граждан РФ на территории РФ (требования локализации согласно новым поправкам 2024)
4. Уведомление регуляторов — при использовании иностранного ПО в критических сегментах необходимо уведомить ФСТЭК/ФСБ

Актуальные изменения:

1. ФЗ-216 от 08.08.2024 г.
2. ФЗ-158 от 22.06.2024 г.

ФЗ-152 от 27.07.2006 г. «О персональных данных»

Дата принятия: 27 июля 2006 года

Основной смысл: Регулирование сбора, хранения и обработки персональных данных граждан РФ

Ключевые статьи для ИБ: Статья 4 — общие требования; Статья 19 — обработка ПДн сотрудниками

Задачи (ст. 3):

1. Защита прав субъектов
2. Регулирование обработки
3. Распределение полномочий
4. Безопасность информации

Ключевые принципы обработки (ст. 5):

1. Законность — только с согласия субъекта.
2. Добросовестность — обработка без обмана или принуждения.
3. Целевая определённость — только для заявленных целей.
4. Минимизация данных — сбор только необходимого объёма.
5. Адекватность и точность — данные должны быть верными.
6. Хранение в установленный срок — не дольше, чем необходимо для цели.

Ключевые понятия:

- **Персональные данные** — любая информация об идентифицированном лице (ФИО, паспорт, телефон, биометрия и т.д.).
- **Специальные категории данных** — расовая принадлежность, убеждения, здоровье, генетические данные и др. (требуют особого согласия).

Закон обязывает организации:

- Получать письменное согласие граждан на обработку данных;
- Обеспечивать техническую защиту информации;
- Назначать ответственного за ИСПДн (информационную систему персональных данных);
- При необходимости проводить оценку безопасности обработки данных.

ФЗ-187 от 26.07.2017 г. «О безопасности КИИ» (Критическая информационная инфраструктура)

Дата принятия: 26 июля 2017 года

Основной смысл: Защита критических объектов и систем, которые обеспечивают безопасность государства

Объекты КИИ: Энергетика, транспорт, здравоохранение, финансовые услуги, связь, гос. Управление

Задачи (ст. 3):

1. Обеспечение безопасности КИИ
2. Выявление угроз
3. Установление требований
4. Создание условий для противодействия
5. Содействие в защите

Ключевые понятия:

- **КИИ (Критическая информационная инфраструктура)** – комплекс взаимосвязанных объектов, обеспечивающих функционирование сфер жизни общества (энергетика, транспорт, финансы, медицина и др.).
- **Объект КИИ** – комплекс организационных, технических и программно-технических средств обработки информации в конкретной сфере.
- **Уровень защиты** – категории 0, 1, 2 (называются по уровню важности для национальной безопасности).
- **Инцидент безопасности КИИ** – событие, приводящее к нарушению конфиденциальности, целостности или доступности информации.
- **КИИ-связанный сектор** – отрасль (энергетика, транспорт, финансы и т.п.), связанная с критической инфраструктурой.

Ключевые принципы обработки:

1. Законность — защита только законных интересов государства.
2. Непрерывность функционирования — обеспечение стабильной работы КИИ.
3. Адаптивность — реагирование на новые угрозы и изменения ландшафта безопасности.
4. Минимизация ущерба — снижение потенциального вреда от кибератак.

Требования к объектам КИИ:

Контроль и мониторинг	Регулярно проверять уязвимости системы безопасности.
Защитные меры	Внедрять средства защиты информации, антивирусы, брандмауэры.
Учет инцидентов	Вести реестр инцидентов и отчитываться перед регулятором.
Обучение сотрудников	Проводить инструктажи по безопасности для персонала.
Планы реагирования	Разрабатывать планы действий при аварийных ситуациях.
Создание реестров	Вести реестр КИИ-объектов и их операторов.

Международные стандарты и соглашения

ISO/IEC 27005:2021 «Информационная безопасность — Управление рисками»

Цикл управления рисками по ISO 27005:

1. Установление контекста
2. Оценка рисков (Определение активов, угроз, уязвимостей)
3. Обработка рисков (Избежать, Снизить, Передать, Принять)
4. Мониторинг и пересмотр

ISO/IEC 27019:2018 «Информационная безопасность для телекоммуникаций» - специализированный стандарт для организаций связи

NIST SP 800-30 Revision 2 «Guide for Conducting Risk Assessments» (США)

GDPR (General Data Protection Regulation) — Общий регламент защиты данных ЕС

Непосредственно не применим в РФ: влияет на компании с клиентами из ЕС

Основные принципы GDPR:

1. Законность обработки данных
2. Ограничение цели
3. Минимизация данных
4. Точность данных
5. Ограничение хранения

PCI DSS — Стандарт безопасности индустрии платежных карт

Обязателен для финансовых организаций работающих с картами Visa, Mastercard и др.

12 требований PCI DSS:

1. Установить процессы защиты данных держателей карт
2. Не хранить данные держателей карт без необходимости
3. Защищать хранимые данные при передаче
4. Обеспечить безопасность всех точек доступа
5. Разработать и поддерживать политики безопасности
6. Регулярно проверять сети и конфигурацию
7. Тестировать безопасность в режиме real-time
8. Ограничить использование учётных записей
9. Регулярно пересматривать доступы
10. Внедрить контроль доступа по принципу наименьших привилегий
11. Регулярно проводить аудит безопасности
12. Разработать процедуры реагирования на инциденты

Аудит и аттестация систем

Аттестация и аудит по приказу ФСТЭК №15/№29

Периодичность: Минимум раз в 3 года для большинства объектов КИИ; ежегодно для критически важных систем

Состав аудита: Проверка политик, мер защиты, технической безопасности, документации на соответствие требованиям ФСТЭК/ФСБ

Документация: Акт аттестации, заключение экспертов, протоколы проверок

Результаты: Отчёт о соответствии, перечень неустранённых недостатков, рекомендации по устранению

Этапы проведения аудита согласно приказу №15:

Этап 1: Подготовительный (2-4 недели)

1. Сбор и анализ документации
2. Определение объектов защиты
3. Формирование плана аудита

Этап 2: Предварительный аудит (1-2 недели)

1. Проверка политик доступа
2. Анализ сегментации сети
3. Проверка логирования и мониторинга

Этап 3: Фактический аудит (2-4 недели)

1. Тестирование мер защиты (сканирование, пентесты)
2. Проверка конфигураций
3. Анализ инцидентов безопасности

Этап 4: Заключительный (1-2 недели)

1. Оформление отчёта о соответствии
2. Выявление нарушений
3. Рекомендации по устранению

Аудит по приказу ФСБ №47 (криптография)

Периодичность: Проверка использования сертифицированных криптографических средств ≥ раз в год

Объекты проверки: Шифрование, средства аутентификации, защита каналов связи

Ответственность: Уведомление ФСБ при использовании незашифрованных протоколов (рекомендуется)

Аудит по ФЗ-152 (персональные данные)

Периодичность: Ежегодный аудит обработки персональных данных, особенно в корпоративных сетях

Ключевые проверки: Регистрация операторов, согласие на обработку, уведомления Роскомнадзора

Результаты: Отчёт о соответствии ФЗ-152 с рекомендациями по улучшению

Сравнительная таблица к аудиту

Тип аудита	Нормативный документ	Периодичность	Результат	Ответственность
ФСТЭК-аудит	Приказ №15, №29	Раз в 3 года (или чаще по требованию)	Акт соответствия	Штрафы до 300 тыс. руб. + отзыв лицензии
ФСБ-аудит	Приказ №47	Раз в 1-2 года	Отчёт о криптографическ ой защите	Уголовная ответственность при грубых нарушениях
Роскомнадзор-аудит	ФЗ-152	Ежегодно или по запросу	Регистрация обработки ПДн	Штрафы от 30 тыс. до 1 млн руб.

Уголовная ответственность

Ответственность за киберпреступления согласно УК РФ

Статья	Описание преступления	Максимальный штраф / ответственность
ст. 272	Невластное проникновение в информационную систему	До 3 лет + компенсация ущерба
ст. 273	Нарушение правил работы с компьютерными данными (хакерство)	До 6 лет + штрафы
ст. 137	Нарушение неприкосновенности частной жизни (утечка персональных данных)	Штрафы до 500 тыс. руб., арест
ст. 274	Создание/распространение вредоносного ПО	До 2 лет + конфискация
ст. 280	Вмешательство в работу КИИ (Кибератаки)	До 5 лет + штрафы

Домашнее задание

- Изучить ФЗ-152 «О персональных данных» (раздел 7 — обязанности оператора)
- Составить чек-лист требований аудита для своей организации согласно приказам ФСТЭК/ФСБ
- Подготовить анализ возможных нарушений в выбранной системе ИБ с ссылками на законы